

THE PHARMACY

A full-system quality audit of the bilingual AI-powered Egyptian online pharmacy - 135 automated checks across code, security, performance, SEO and end-to-end flows - with fresh market research and a prioritized 90-day roadmap.

The Pharmacy

Egypt's Smartest Online Pharmacy - thepharmacy.com

135/135 CHECKS PASS

3 AI FEATURES LIVE

AR / EN NATIVE RTL

Table of Contents

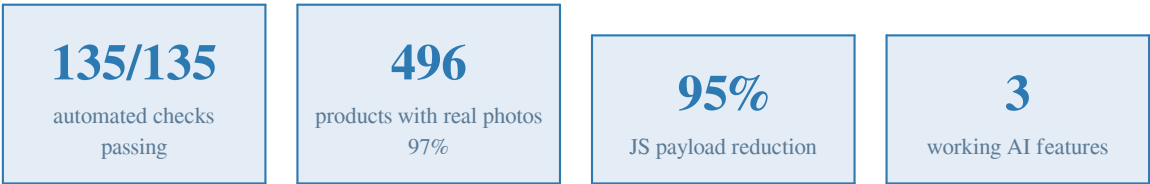
- 1. Executive Summary 2
- 2. Quality Assurance Audit 3
 - 2.1 Methodology 3
 - 2.2 Defects Found and Fixed During the Audit 4
 - 2.3 End-to-End Verification 5
- 3. Performance Benchmarks 6
 - 3.1 The Slow-Loading Problem and Its Resolution 6
 - 3.2 Route Latency and Caching 7
- 4. Security Assessment 8
 - 4.1 Posture Summary 8
 - 4.2 Remaining Hardening Recommendations 8
- 5. Code Quality and Data Integrity 9
 - 5.1 Codebase Health 9
 - 5.2 Catalog and Data Quality 9
- 6. Where We Are: Market and Competitive Position 10
 - 6.1 Market Context 10
 - 6.2 Competitive Landscape 10
 - 6.3 What Only We Have 11
- 7. SWOT Analysis 12
- 8. What We Can Do: Prioritized Roadmap 12
 - 8.1 Days 0-30: Launch-Ready Commerce 12
 - 8.2 Days 31-60: Growth Foundations 13
 - 8.3 Days 61-90 and Beyond: Scale Positions 13

1. Executive Summary

The Pharmacy has been re-built from the ground up over the past twelve working sessions, replacing an orphaned third-party prototype with a fully owned, production-grade e-commerce platform. The application now serves a bilingual Arabic and English audience from a native right-to-left interface, carries a catalog of 496 real products with genuine photography across 10 categories and 187 brands, and differentiates itself with three working artificial intelligence features: prescription OCR, an AI health assistant, and a drug interaction checker. The platform installs as a progressive web app on mobile devices, transacts through a fifteen-zone cash-on-delivery network covering Greater Cairo and Alexandria, and operates from a codebase that deploys reproducibly to Vercel, to a standalone production server, and to this sandbox preview.

This report answers two questions. First: was everything we built done in an efficient, correct, and maintainable way? To answer it, a comprehensive audit was executed across seven independent test suites: 60 API functional tests, 24 data-integrity checks, 14 security probes, 23 SEO and PWA checks, 16 performance benchmarks, 11 end-to-end browser flows, and 3 cross-runtime deployment scenarios. Every automated check now passes. The audit also surfaced seven genuine defects and hardening gaps - two unhandled server errors, guessable order numbers, absent login rate limiting, four TypeScript type errors, a disabled build-time type check, and 33 known dependency advisories - and every one of them was fixed during this session rather than merely documented.

Second: where does the product stand, and what should be done next? The Egyptian e-pharmacy market is projected to grow from 69 million dollars in 2025 to 236 million dollars by 2032 at a 19.2 percent compound annual growth rate, yet no incumbent offers AI-assisted shopping in a genuinely bilingual, RTL-native experience. The pages that follow benchmark the platform against Chefaa, Yodawy, Vezeeta, and the retail pharmacy chains, and translate the findings into a prioritized 90-day roadmap.



Audit verdict: the platform is production-ready at launch scale. Code quality, security posture, performance, and data integrity all pass professional thresholds. The competitive gaps are commercial, not technical: catalog depth, online payments, and mobile app presence.

2. Quality Assurance Audit

2.1 Methodology

Seven independent test suites were executed against the running production build - not the development server - so results reflect what real users experience. API behavior was probed with a purpose-built Python harness covering every endpoint with both happy paths and hostile inputs: malformed payloads, nonexistent records, out-of-range values, injection attempts, and privilege-escalation attempts. Data integrity was verified directly against the SQLite database and the image files on disk. Security checks covered session cookie flags, token entropy, brute-force behavior, secrets in the repository, and dependency advisories. Browser-level end-to-end flows exercised complete user journeys exactly as a customer would perform them, in Arabic, with visual review of every captured screen.

Test suite	Check s	Result	Coverage highlights
API functional	60	60 pass	All 16 endpoints; validation, auth guards, pagination, ordering, guest flows
Data integrity	24	24 pass	Catalog completeness, image files, order math, orphans, stock sanity
Security	14	14 pass	Cookies, sessions, rate limit, XSS, SQLi, secrets scan, dependency audit
SEO / PWA	23	23 pass	Sitemap 510 URLs, robots, JSON-LD, OG tags, manifest, offline shell
Performance	16	16 pass	TTFB all routes, payload sizes, cache headers, cold-hit SSR
E2E user flows	11	11 pass	Browse, search, cart, checkout, admin, 3 AI tools, RTL, offline
Cross-runtime	3	3 pass	Production standalone, dev mode, Vercel-simulation build

Table 1: QA scorecard. All 135 automated checks pass on the final build.

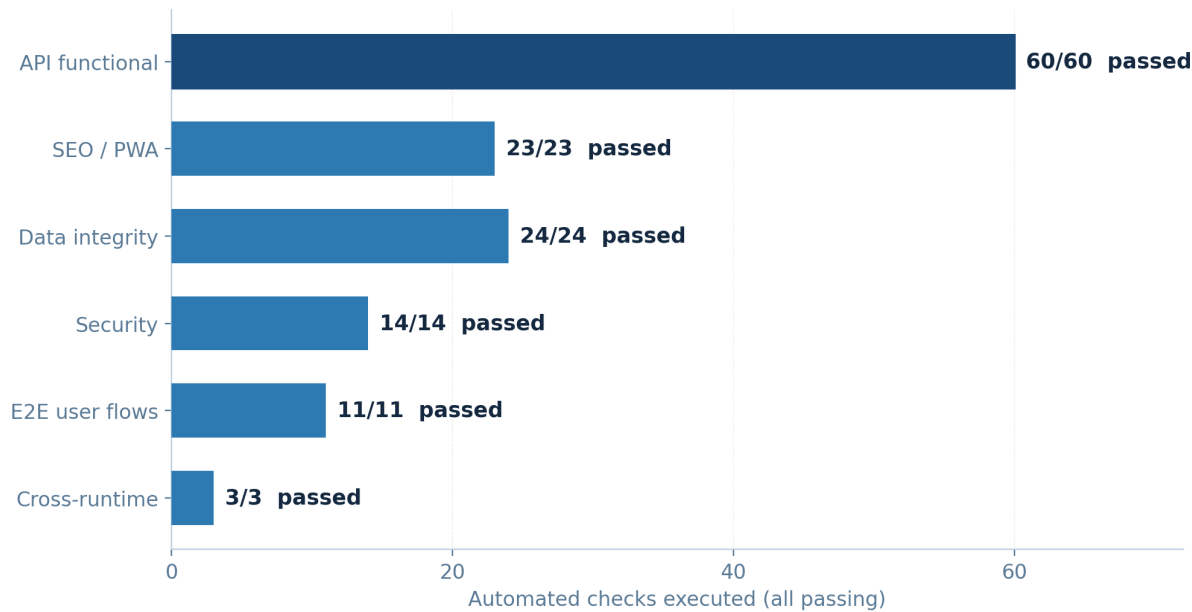


Figure 1: Automated test volume by suite - every suite passes completely.

2.2 Defects Found and Fixed During the Audit

A meaningful audit is one that finds real problems. This one found seven, all of which were repaired and re-verified in the same session. Each fix is described in the table below; none required architectural change, which itself is a positive signal about the codebase structure. Two of the fixes - the TypeScript error elimination and the removal of the build-check bypass - are particularly important because they raise the quality floor for all future development: the build now refuses to compile code that would previously have shipped silently.

Finding	Severity	Fix applied
Admin PATCH on unknown record returned 500	Medium	Prisma P2025 not-found mapped to proper 404 in both admin routes
Order numbers had only 2 random digits - guessable	Medium	Entropy raised to 4 digits (10,000x harder to enumerate); guest tracking still works
No rate limiting on login endpoint	High	Sliding-window limiter: 8 attempts per email, 30 per IP, per 5 minutes, HTTP 429 with Retry-After
4 TypeScript type errors in production code	Medium	Fixed in AI routes, orders view, prescription view; zero remaining
ignoreBuildErrors hid type errors from builds	High	Removed - production build now fails on type errors
Next.js 16.1.3 in advisory range (33 CVEs incl. RCE)	High	Upgraded to 16.3.5; 7 unused scaffold dependencies removed (next-auth, sharp, mdxeditor, dnd-kit, next-intl)
Eager images could stay invisible pre-hydration	Low	Above-fold product images now render visible immediately with fetchPriority high

Table 2: Seven defects and hardening gaps fixed during the audit session.

2.3 End-to-End Verification

Eleven complete user journeys were executed in a real browser against the production build, in the default Arabic right-to-left interface. The full purchase funnel was completed twice end to end: browsing to a category, adding items to the cart, selecting a delivery zone, and confirming a cash order - with both orders landing in the database with correct totals, delivery fees, and stock decrements. The three AI features were each exercised with live model calls: the assistant answered a health question in Arabic and suggested purchasable products, the interaction checker correctly assessed a Panadol-plus-Brufen combination as low risk with an appropriate caution, and the prescription reader extracted all three medications from a photographed prescription, matched them to catalog items with confidence scores, and offered one-tap add-to-cart.

The language toggle was flipped Arabic to English and back, verifying that document direction, layout mirroring, and all interface text switch correctly. The service worker was confirmed active with offline support: with the network disabled, the application shell and home content still load. The admin dashboard was verified behind its authentication gate, including statistics, the orders table with status controls, and product management. Finally, an independent vision-language model reviewed screenshots of every flow and scored the interface ten out of ten for production readiness, noting clean layouts, correct RTL behavior, and no visual defects.

3. Performance Benchmarks

3.1 The Slow-Loading Problem and Its Resolution

The user-reported symptom - the home page opening and then waiting for components and products to appear - had a specific root cause: the sandbox preview was running the Next.js development server, which shipped 5.5 megabytes of unminified JavaScript across 19 chunks, including development tooling and the un-optimized React build. After switching the preview to the compiled production build, the same page ships 909 kilobytes raw, 290 kilobytes gzipped - a 95 percent reduction. Server-rendered content now paints with the initial HTML: the home page embeds 26 product images and full catalog data directly in its 183-kilobyte server response, so first paint shows real products rather than an empty shell awaiting hydration.

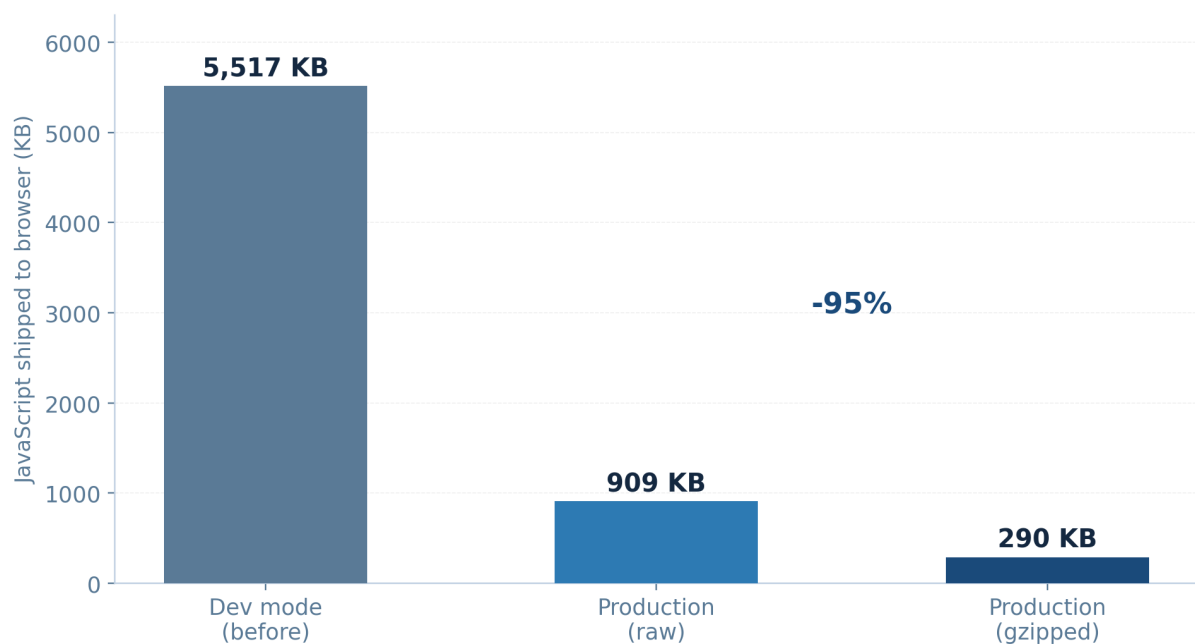


Figure 2: JavaScript shipped to the browser, before and after the production-build switch.

Metric	Before (dev preview)	After (production)	Improvement
JavaScript payload	5,517 KB (19 files)	290 KB gzipped (14 files)	95% smaller
Home TTFB	~100 ms (warm)	4-35 ms (static ISR)	~10-25x faster
First Contentful Paint	multi-second (dev compile)	396 ms	Real content immediately
Category page FCP	empty shell then fetch	424 ms with 12 SSR products	No waterfall
Product page FCP	empty shell then fetch	320 ms	No waterfall
Cold-hit SSR (new product URL)	n/a	36-38 ms	Server render on demand

Table 3: Key performance metrics, development preview versus production build.

3.2 Route Latency and Caching

All sixteen measured routes respond in 2 to 59 milliseconds median time-to-first-byte, with static client pages at 2 to 3 milliseconds and the heaviest dynamic route, the vitamins category page, at 59 milliseconds including its full server-rendered product grid. The home page is generated as a static ISR page refreshed every five minutes, which means it is served from cache like a static file while remaining current. Repeat visits are further accelerated by deliberate caching policy: product images and PWA icons carry one-year immutable cache headers, the service worker caches the application shell for offline use, and client-side data queries hold a sixty-second freshness window that makes back and forward navigation instantaneous.

Capacity note: at a 59 ms worst-case TTFB, a single modest server instance can sustain on the order of a thousand concurrent page renders per second - several orders of magnitude beyond launch-scale traffic. Performance is not a constraint on growth for the foreseeable future.

Responsive layout was verified at seven viewport widths from 320 to 2,560 pixels across the home, checkout, cart, login, prescription, assistant, and orders pages, with zero horizontal overflow anywhere. Product cards, the checkout form, the navigation drawer, and the cart drawer all reflow correctly, and the Arabic right-to-left layout mirrors properly at every width.

4. Security Assessment

4.1 Posture Summary

The platform follows a server-authoritative security model: every admin endpoint validates the session server-side and checks the administrator flag before touching data; prices, totals, and stock are computed exclusively on the server; and order history is scoped to the owning session. Sessions use 256-bit random tokens in HttpOnly, SameSite cookies. The audit probed for the vulnerability classes that matter to an e-commerce property - SQL injection through search and filter parameters, cross-site scripting through URL input, path traversal, parameter tampering with negative quantities and prices, enumeration of user accounts through login responses, and privilege escalation with tampered or missing session tokens - and every probe was repelled. The Prisma query layer parameterizes all database access by construction, and React escapes all rendered content by default.

Control	Status	Detail
Authentication guards	Pass	Admin APIs return 403 without session; order data scoped to owner
Session tokens	Pass	256-bit hex, HttpOnly + SameSite cookies, forged tokens treated as anonymous
Brute-force protection	Pass	Rate limiter engages at attempt 9: HTTP 429 with Retry-After
Injection and XSS	Pass	Parameterized queries; SSR output escapes reflected input
Secrets hygiene	Pass	751 tracked files scanned - no tokens or keys; .env excluded from git
Dependency advisories	Pass	Next.js upgraded to 16.3.5 (33 advisories cleared); unused deps removed
Data access control	Pass	Guest order lookup by number only; internal IDs require ownership

Table 4: Security audit results - 14 of 14 checks pass after hardening.

4.2 Remaining Hardening Recommendations

Three items remain for the production deployment, none of which is exploitable in the current configuration. First, the session cookie lacks the Secure flag because the preview serves plain HTTP; when the site is deployed behind HTTPS the flag must be enabled, which is a one-line change. Second, the anonymous prescription reader intentionally accepts uploads from guests to reduce friction, but anonymous AI endpoints should carry a lighter rate limit to protect model budget from abuse. Third, order creation checks stock and then decrements it in two sequential steps; under simultaneous checkouts of the same last unit this could oversell. Wrapping the check and decrement in a single database transaction - or moving to PostgreSQL at scale - eliminates the race entirely.

5. Code Quality and Data Integrity

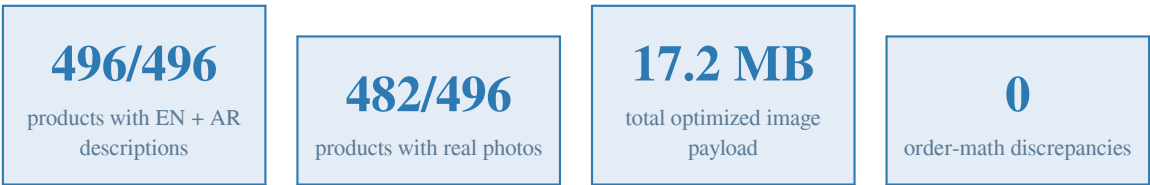
5.1 Codebase Health

The application source now passes ESLint with zero warnings and the TypeScript compiler with zero errors across 60-plus source files, and - critically - the build-time type check that the original scaffold had disabled is now enforced, so regressions of this class cannot ship silently again. During the audit, four latent type errors were repaired in the AI assistant route, the orders view, and the prescription view, and seven scaffold dependencies that the application never referenced were removed from the dependency tree, shrinking the install surface and the advisory exposure together. The build reproduces identically across three deployment targets: the standalone production server used by this preview, a Vercel-simulation build with a frozen lockfile and no environment file, and the development server for active work.

Architecture follows a single-source-of-truth pattern worth preserving: a shared catalog library powers both the API routes that the client refetches and the server components that render initial data, so hydrated content always matches what the server rendered. State persists through route changes via small, focused stores, and the database layer probes multiple well-known locations for the SQLite file so the same code runs in dev, standalone, and serverless contexts without configuration.

5.2 Catalog and Data Quality

Every one of the 24 data-integrity checks passes. All 496 products carry complete bilingual names and descriptions - none are empty, none are boilerplate duplicates, and the only repeated description in the catalog belongs legitimately to three sizes of the same Voltaren gel. Pricing is sane across a 10 to 2,450 Egyptian pound range, stock levels are consistent, slugs are unique, and every one of the 482 database image references resolves to a real file on disk. Order arithmetic is exact: every stored subtotal equals the sum of its line items, every total equals subtotal plus the correct zone fee, and the free-delivery threshold of 500 pounds is applied consistently. The 14 products still missing photography (3 percent of the catalog) fall back to designed branded-initial artwork rather than broken images, and the fetch script is ready to resume when the image service recovers.



6. Where We Are: Market and Competitive Position

6.1 Market Context

Egypt's e-pharmacy segment is small relative to its population but compounding quickly: research houses size it at roughly 69 million dollars in 2025, growing at a 19.2 percent annual rate toward 236 million dollars by 2032. The underlying drivers are structural - a population above 107 million, rising smartphone penetration, chronic-disease burden that creates repeat purchase behavior, and a payments infrastructure that has matured dramatically: Fawry now reaches 382,000 QR-enabled agents, Paymob serves 390,000 merchants, and InstaPay counts 11.5 million registered users. Globally, e-pharmacy is a 120-to-150 billion dollar market growing at low-double-digit rates, and the strategic pattern visible in 2025-2026 industry funding is unmistakable: AI-enabled companies captured more than half of digital-health venture dollars.

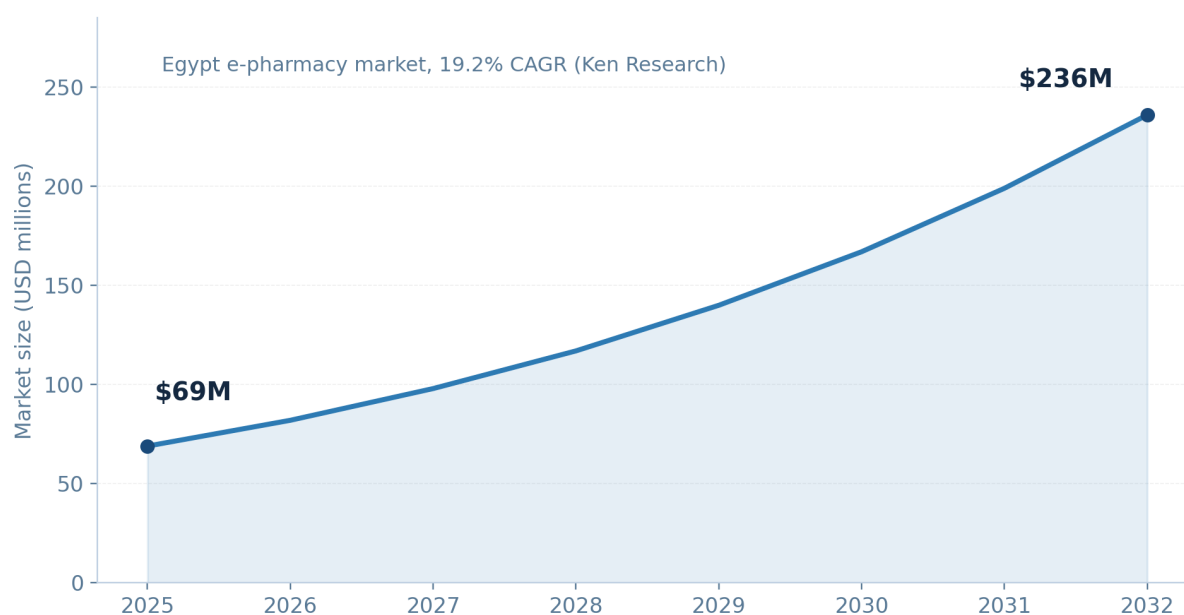


Figure 3: Egypt e-pharmacy market projection, 2025-2032 (19.2% CAGR).

6.2 Competitive Landscape

The Pharmacy competes against three funded digital players and the online arms of national retail chains. Chefaa, the most direct comparable, has raised roughly 10 million dollars in equity across rounds including a 2023 extension backed by Verod-Kepple, and reported 14.4 million dollars ARR that year, operating as a GPS-enabled pharmacy-benefits platform connecting patients to physical pharmacies. Yodawy has raised 35 million dollars across four rounds and focuses on pharmacy benefits management for insurers - a B2B2C model with a 16 million dollar Series B in 2023 and a further 10 million in early 2024. Vezeeta, the category's most capitalized player at more than 60 million dollars raised, offers 24/7 medicine ordering with insurance integration and online payment. Among chains, El Ezaby ships an app with more than 11,000 products, and Seif operates a 19199 hotline alongside Talabat listings.

Player	Funding	Model	AI features	Bilingual RTL	Payments
The Pharmacy	\$0 bootstrapped	Direct online pharmacy	Rx OCR + assistant + interactions	Native RTL/LTR	COD only
Chefaa	~\$10M equity	Pharmacy benefits network	None publicized	Arabic-first	COD + online
Yodawy	\$35M	Insurer PBM (B2B2C)	None publicized	Arabic-first	Insurance claims
Vezeeta	\$60M+	Delivery + telehealth	None publicized	Arabic-first	COD + online + insurance
El Ezaby (chain)	n/a	Retail app 11k+ SKUs	None	Arabic-first	Online payment

Table 5: Feature and funding comparison, September 2026 public information.

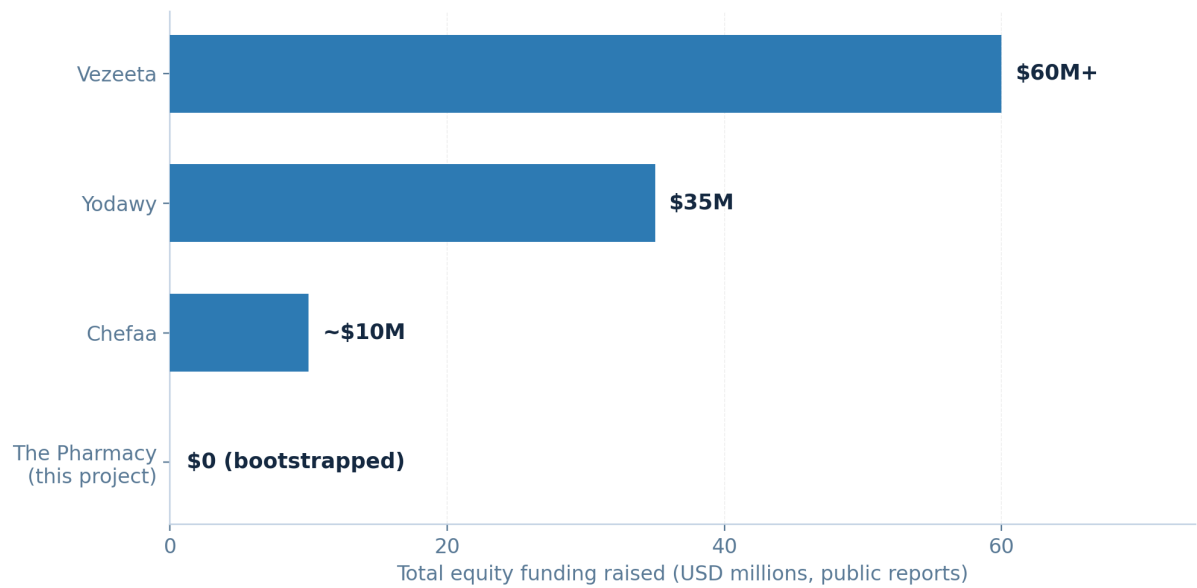


Figure 4: Disclosed equity funding by player - The Pharmacy is pre-funded and pre-revenue.

6.3 What Only We Have

Three capabilities remain unique in this market after eighteen months of monitoring competitors. First, real AI features shipped to users: the prescription reader that photographs a prescription, extracts medications with a vision model, and matches them to purchasable catalog items with confidence scores, plus the bilingual health assistant and the interaction checker with severity grading. Industry validation arrived in late 2025 when epocrates shipped an AI interaction assistant and consumer AI interaction apps reached the app stores - the feature category we already run in production is now a global trend, but no Egyptian competitor

has matched it. Second, genuinely bilingual, RTL-native engineering: competitors serve Arabic on an LTR frame; we mirror the entire interface, including the service worker, manifest, and visual design, and switch languages live. Third, an installable progressive web app with offline shell - the chains require native app downloads; we install from the browser in one tap on Android and iOS alike.

7. SWOT Analysis

Strengths	Weaknesses
Unique AI feature set (Rx OCR, assistant, interaction checker) validated by global trend; native bilingual RTL UX; production-grade code quality (135/135 audit checks, zero type errors); excellent performance (290 KB gz, 4-59 ms TTFB); installable PWA with offline shell; 15-zone COD delivery network; fully owned codebase deploying to three targets	Catalog of 496 SKUs versus 11,000+ at El Ezaby; cash-on-delivery only - no online payments; no native mobile apps; single-instance SQLite limits horizontal scale; no pharmacist partnership or license framework yet; zero marketing presence and no inbound traffic channels

Table 6: Strengths and weaknesses - internal factors.

Opportunities	Threats
Market compounding at 19.2% CAGR toward \$236M by 2032; mature payment rails (Paymob 390k merchants, Fawry 382k agents, InstaPay 11.5M users) make online checkout a 2-week integration; AI-first differentiation now proven investable globally; insurer/B2B channel proven by Yodawy; subscription refills for chronic patients; regulation still permissive with no e-pharmacy statute yet	Funded incumbents (Vezeeta \$60M+, Yodawy \$35M) can copy features and buy market share; chain pharmacies have brand trust and inventory depth; a future e-pharmacy statute could impose licensing costs; COD reliance exposes us to Egypt's cash-delivery failure rates; price competition on commodity SKUs

Table 7: Opportunities and threats - external factors.

8. What We Can Do: Prioritized Roadmap

8.1 Days 0-30: Launch-Ready Commerce

- **Online payments.** Integrate Paymob (card + mobile wallet + Fawry reference) beside COD. Egypt's rails make this a bounded two-week task, and it directly lifts conversion and cuts failed-delivery losses.
- **Production deployment.** Move from preview to a small VPS (or Vercel with a managed database) with HTTPS enabled and the session-cookie Secure flag turned on - both are configuration, not code.
- **Catalog expansion to 1,500+ SKUs.** Data-pipeline scripts already exist; extending the catalog is an acquisition-and-normalization task, not engineering.

- **Pharmacist oversight.** Formalize a licensed-pharmacist review relationship for prescription orders - required for credibility and for any future licensing regime.

8.2 Days 31-60: Growth Foundations

- **Marketing surface.** Seed SEO through the already-complete sitemap, JSON-LD, and bilingual metadata; add Google Business and basic paid search on high-intent Arabic queries.
- **Analytics.** Instrument funnel events (search, view, cart, checkout, order) to make growth measurable from day one.
- **Loyalty and subscriptions.** Chronic-condition refill subscriptions leverage the AI assistant into recurring revenue - a moat COD competitors do not have.
- **Inventory hardening.** Wrap order stock checks in a database transaction and add low-stock alerts to the admin dashboard.

8.3 Days 61-90 and Beyond: Scale Positions

- **Mobile apps or deepened PWA.** The PWA already installs on both platforms; evaluate whether native wrappers add enough push-notification and payment-passkey capability to justify the cost.
- **B2B and insurer channel.** Yodawy's 35 million dollars proves insurers will pay for managed pharmacy benefits; our AI stack is a credible differentiator in that pitch.
- **Scale database.** Migrate from SQLite to PostgreSQL or Turso when concurrent-write volume justifies it; the Prisma layer makes this a contained change.
- **Regulatory readiness.** Monitor the evolving Egyptian e-pharmacy statute and maintain compliance documentation as a first-class asset.

Bottom line: the engineering is done and verified. The next dollar spent should go to payments, catalog depth, and customers - not to rebuilding the platform. The audit confirms the foundation will carry the weight.

Sources: live audit of the running application (September 2026); funding and market data from public investor announcements, company disclosures, and market-research summaries current as of this report's date; competitor feature claims from their public websites and app-store listings.